PRODUCT REQUIREMENT DOCUMENT (PRD)

UMHackathon 2026

umhackathon@um.edu.my

© UMHackathon 2026

Email: umhackathon@um.edu.my

Table of Contents

1. Project Overview 1
2. Background & Business Objective 1
3. Product Purpose 2
4. System Functionalities 2
5. User Stories & Use Cases 3
6. Features Included (Scope Definition) 3
7. Features Not Included (Scope Control) 3
8. Assumptions & Constraints 4
9. Risks & Questions Throughout Development 4

© UMHackathon 2026

Email: umhackathon@um.edu.my

Project Name: Kudoscan Bot - Phishing Detector

Version: 1.0

1. Project Overview

- **Problem Statement:** Everyday users receive suspicious emails and messages containing potentially malicious links, but have no easy, instant way to verify whether a link is a phishing attempt. Checking URLs, IP addresses and email manually or requires technical knowledge most users do not have, and existing browser-based tools are not accessible mid-conversation. As a result, many users either ignore the risk or fall victim to credential harvesting and malware delivery.

- **Target Domain:** Elders and person who specifically phishing detection accessible to non-technical everyday users through a familiar messaging platform such as Telegram.

- **Proposed Solution Summary:** Kudoscan Bot is a Telegram chatbot where users forward a suspicious email or paste a URL or IP adress or image and files directly into the chat. The bot extracts the link, performs multi-source threat intelligence checks, and replies with a clear message whether the link is safe, suspicious, or confirmed phishing. It will explain in plain language anyone can understand.

© UMHackathon 2026

Email: umhackathon@um.edu.my

2. Background & Business Objective

- **Background of the Problem:** Phishing remains the most common entry point for cyberattacks globally, with billions of malicious emails sent daily. The challenge is not only at the enterprise level, but ordinary individuals also receive fake banking alerts, parcel delivery scams, and account verification requests every day. These messages are designed to look legitimate, and distinguishing a real link from a fake one requires knowing how to inspect URLs, check domain ages, and cross-reference threat databases. There is a significant gap between the threat and the average person's ability to assess it.

- **Importance of Solving This Issue:** A single click on a phishing link can lead to stolen credentials, financial loss, malware infection, or identity theft. For employees, interacting with malicious links in work-related communications can also expose organizational systems and sensitive data. Integrating a zero-friction link verification feature directly within the messaging apps users already rely on daily reduces the effort required to validate suspicious links, lowers barriers to safe decision-making, and empowers users to protect themselves before clicking.

- **Strategic Fit / Impact:** Telegram has over 900 million active users globally and is widely used across Southeast Asia, making it an ideal delivery platform for a security tool targeting broad accessibility. By meeting users on a platform, they already trust and use Kudoscan Bot lowers adoption friction to near zero. The bot aligns with growing national and organizational cybersecurity awareness initiatives, and its simple interface makes it suitable for users across all technical skill levels.

© UMHackathon 2026

3. Product Purpose

3.1. Main Goal of the System: To provide any Telegram user with an instant, easy-to-understand verdict on whether a link extracted from a suspicious email or message or IP address or files is a phishing attempt without requiring any technical knowledge from the user.

3.2. Intended Users (Target Audience):

- **General public** - individuals who receive suspicious emails or messages in their personal life
- **Students** - young users unfamiliar with phishing tactics who rely on email for academic communications
- **Small business owners** – person who lack a dedicated IT security team but receive business-targeted phishing attempts

© UMHackathon 2026

4. System Functionalities

4.1. Description

The system is a Telegram bot that allows users to submit suspicious content as email text, a directly pasted URL, or an uploaded screenshot image. A large language model (LLM) serves as the analysis engine, extracting embedded links, coordinating calls to the VirusTotal API, and evaluating URL characteristics alongside any accompanying message context. For image submissions, a dedicated OCR engine first extracts text and URLs before analysis. Based on this analysis, the system generates a clear, plain-language verdict for the user. The bot is designed to be conversational and intuitive, enabling users to interact with it as they would in a typical chat experience by simply sending a message, link, or image and receiving an immediate assessment.

4.2. Key Functionalities

4.2.1 Input Handling via Telegram

- Accept a URL pasted directly into the Telegram chat
- Accept a forwarded or copy-pasted email body containing one or more links
- Extract all URLs from the submitted text automatically
- Handle shortened URLs (e.g., bit.ly, tinyurl) by resolving them to their final destination before analysis
- Accept screenshots of suspicious SMS (smishing), WhatsApp messages, or emails uploaded directly as image files.
- Utilize a dedicated cloud-based Optical Character Recognition (OCR) engine equipped with digital upscaling to reliably extract text and hidden URLs, even from images heavily compressed by Telegram.

© UMHackathon 2026

4.2.2 Threat Intelligence Checks

- VirusTotal API: Submit extracted URL for scanning against 70+ antivirus and URL scanning engines

4.2.3 GLM-Powered Analysis & Reasoning

- Combine VirusTotal API signals into a unified analysis
- Analyse URL structure for suspicious patterns: random subdomains, homograph characters, misleading TLDs.
- Analyse the surrounding email text for psychological manipulation such as urgency language, authority impersonation, threats, and reward baiting
- Produce a Threat Verdict, Low / Medium / High with a confidence level
- Generate a plain-language explanation of exactly why the link is dangerous or safe, written for a non-technical user

4.2.4 Telegram Bot Response

- Reply with a clear verdict label.
- Provide a brief, friendly explanation in plain English of what was found.
- List the key reasons behind the verdict.
- If suspicious but not confirmed, advise the user not to click and suggest contacting the sender through a verified channel

© UMHackathon 2026

4.2.5 Edge Case Handling

- **API unavailable or rate-limited:** Bot logs the failure, notifies the user that the scan service is temporarily unavailable, and proceeds with heuristic URL analysis only.
- **No URL found in input:** Bot replies asking the user to paste just the link or the email text containing the link
- **Multiple URLs in one email:** Bot checks each URL individually and reports a combined verdict, flagging which specific link is dangerous

4.3. AI Model & Prompt Design

4.3.1 Model Selection

The system uses the Z AI GLM as its core reasoning and synthesis engine. The GLM was selected for this use case because:

- **Natural language generation:** Converts raw API JSON responses into friendly, human-readable explanations suitable for non-technical Telegram users
- **Entity extraction:** Reliably identifies and extracts URLs from messy, copy-pasted email bodies that may include formatting artefacts, signatures, and quoted reply chains
- **Contextual reasoning:** Can combine URL structure signals, API data, and email text tone into a holistic verdict rather than relying on any single data point
- **Instruction following:** Produces consistently structured bot replies that render well in Telegram's chat interface

© UMHackathon 2026

4.3.2 Prompting Strategy

The system uses a two-stage prompting approach:

- Stage 1 - Extraction Prompt (zero-shot): A focused prompt instructs the GLM to extract all URLs from the user's raw input and identify any urgency or manipulation language in the surrounding text. This is zero-shot because URL extraction is a well-defined, unambiguous task.

- Stage 2 - Synthesis Prompt (few-shot with examples): The GLM receives the extracted URLs, all VirusTotal scan results, and the message analysis. Few-shot examples are provided showing how to combine multiple weak signals such as borderline VirusTotal score, new domain, urgency text into a final verdict with a clear explanation. Few-shot is used here because verdict calibration deciding when 'Medium Risk' becomes 'High Risk' benefits from demonstrated examples.

This two-stage approach keeps each prompt focused and avoids context overload, improving consistency and reducing hallucination risk.

4.3.3 Context & Input Handling

- **Maximum input size:** To comfortably handles a full email body including headers, signatures, and quoted replies.
- **Inputs within the limit:** Processed in full of no truncation.
- **Inputs exceeding the limit:** The GLM performs a summarization pass on the email body, preserving all URLs intact before passing to the analysis pipeline. URLs are never truncated.
- **Inputs with no recognisable content**: Bot replies asking the user to copy-paste the text content or type out the URL manually.
- **Image OCR Processing:** When an image is submitted, it bypasses standard text handling and is routed to a dedicated OCR API. The engine extracts the raw text

© UMHackathon 2026

from the image, which is then subjected to the same 300-character truncation limit before being passed to the GLM for analysis.

4.3.4 Fallback & Failure Behavior

- **Hallucinated threat claims:** All verdict statements must be grounded in a specific API result or URL structural feature. If the GLM generates a warning not traceable to any data point, the output validation layer strips it and replaces with 'Unable to verify, proceed with caution'.
- **VirusTotal returns no result:** Bot replies: 'We could not reach our scanning services right now. As a precaution, do not click this link. Try again in a few minutes or contact your IT support.'
- **Retry logic:** The VirusTotal API call is retried once on failure before the fallback path is triggered.
- **Off-format GLM output:** If the GLM response does not contain the expected verdict structure, a format-correction prompt is issued automatically for one retry before a generic caution message is returned to the user.

© UMHackathon 2026

5. User Stories & Use Cases

5.1 User Stories:

- As a regular user, I want to paste a suspicious link into the Telegram bot so that I can find out if it is safe to click before I open it.
- As a non-technical user, I want the bot to explain in simple words why a link is dangerous so that I understand the risk and know what to do next.
- As a user who received an email with multiple links, I want the bot to check all the links at once so that I do not have to submit them one by one.
- As a user, I want the bot to still give me a useful response even if some of its scanning tools are temporarily unavailable so that I am not left without guidance.

5.2 Use Cases (Main Interactions):

Use Case 1: Single URL Check

User copies a link from a suspicious email and pastes it directly into the Telegram bot chat. The bot detects the URL, runs a VirusTotal check, and replies within 10 seconds: ‘ HIGH RISK DETECTED! This link leads to a fake Maybank login page. The domain was registered 4 days ago and was flagged by 18 out of 72 security engines. Do not enter your credentials. Delete this email.’

Use Case 2: Shortened URL

User pastes a bit.ly shortened link. The bot first resolves the shortened URL to its final destination (e.g., http://paypa1-secure-login.xyz/account), then runs the full threat check on the resolved URL. The verdict is returned based on the actual destination, not the shortened form.

© UMHackathon 2026

Use Case 3: API Partial Failure

User submits a suspicious URL. VirusTotal returns a rate-limit error. The bot logs this, proceeds with heuristic URL analysis, and returns: ‘MEDIUM RISK! The domain was registered 6 days ago and shows patterns consistent with credential harvesting. Our scanning service was temporarily unavailable. We recommend not clicking this link.’

Use Case 4: No URL Detected

User sends a text message that does not contain a URL such as they typed a question instead. The bot replies: 'I did not find a link in your message. Please paste the URL or the email text containing the suspicious link, and I will check it for you.'

Use Case 5: Smishing (SMS Phishing) Screenshot Analysis

A user receives a suspicious SMS containing a link and takes a screenshot of it. They upload the screenshot directly to the Telegram bot. The bot routes the image to the OCR engine, which extracts the embedded text and URL. The extracted URL is then submitted to VirusTotal for threat analysis. The bot replies: ‘MEDIUM RISK! A link was found in your screenshot pointing to a domain flagged by 12 out of 72 security engines. This may be a smishing (SMS phishing) attempt. Do not click the link and delete the message.’

© UMHackathon 2026
Email: umhackathon@um.edu.my

6. Features Included (Scope Definition)

- Telegram bot interface where users interact entirely within Telegram, no app download or registration required
- URL extraction from raw email text or direct URL paste
- Screenshot and image upload support for SMS, WhatsApp, and email phishing detection
- Cloud-based OCR engine with digital upscaling for text and URL extraction from compressed images
- Shortened URL resolution before scanning
- Multi-source threat intelligence using VirusTotal API
- GLM-powered synthesis of API results with URL structural analysis and email text tone analysis
- Threat verdict with three levels which are Low, Medium, High
- Plain-language explanation of verdict with specific reasons listed
- Handling of multiple URLs within a single submitted email
- Graceful API failure fallback with partial-check labelling
- Edge case handling: shortened links, no URL found, multiple URLs, unreadable images

© UMHackathon 2026

Email: umhackathon@um.edu.my

7. Features Not Included (Scope Control)

- Direct email provider integration where users must manually copy-paste email content
- Automated quarantine or deletion of phishing emails from the user's inbox
- Support for platforms other than Telegram in v1.0

8. Assumptions & Constraints

8.1 Technical Constraints

- **Telegram Bot API Rate Limit:** The Telegram Bot API supports up to 30 messages per second per bot. For high-traffic usage, a queue management mechanism ensures requests are processed reliably without message loss or delivery failures.

- **VirusTotal API Rate Limit:** The free tier of the VirusTotal API allows up to 4 requests per minute. During periods of high demand, scan requests are queued to remain within usage limits. For production-scale deployment, a premium subscription is recommended to support higher throughput and lower latency.

- **URL Accessibility Constraints:** The system can only analyze URLs that are publicly accessible and resolvable over the internet. Internal network addresses, localhost domains, private IP ranges, and non-public resources cannot be fully scanned and are therefore classified as unverifiable.

© UMHackathon 2026

8.2 Performance Constraints

- **Target response time:** under 15 seconds for a standard single-URL check
- **Maximum input length:** Longer inputs trigger summarization before URL extraction.
- **Concurrent Users:** The bot is designed to support up to 100 simultaneous scan requests in boversion 1.0 through asynchronous processing.

8.3 User Input Assumptions

- Users are expected to copy-paste email text or URLs into the bot where the system does not have access to the user's email inbox directly
- Users are assumed to be acting in good faith. The system does not include adversarial input detection for users attempting to manipulate the GLM.
- The bot assumes the user has a Telegram account. No other accounts, logins, or apps are required.

© UMHackathon 2026

9. Risks & Questions Throughout Development

Risk 1: False Positives Legitimate Links Flagged as Phishing

A legitimate link, such as one from a newly launched website or service, may be incorrectly flagged as high risk due to factors like a recently registered domain. To reduce false positives, the system uses a multi-signal evaluation approach rather than relying on a single API result. A new domain alone does not result in a high-risk classification. It must be supported by additional indicators such as threat intelligence flags, suspicious URL patterns, or credential-harvesting detection. In uncertain cases, the system returns a Medium Risk verdict and advises users to verify the link through a trusted source instead of labeling it definitively as high risk.

Risk 2: API Rate Limiting During Viral Phishing Campaigns

During active phishing campaigns, many users may submit the same malicious URL at the same time, which can quickly exhaust free-tier API quotas. To address this, the system uses URL-level caching with a 6-hour time-to-live (TTL), allowing the first scan result to be reused for all subsequent requests of the same URL within that period. This significantly reduces API usage by limiting scans to one request per unique URL every six hours, regardless of submission volume. For production deployment, upgrading to premium API tiers is recommended to ensure scalability and consistent performance.

Risk 3: Users Submitting Sensitive Personal Data

Users may submit full email content that contains sensitive personal information, such as names, account numbers, or credentials included in phishing messages. To protect user privacy, submitted content is processed in memory for analysis and is not permanently stored or logged beyond the active session. On first use, the bot presents a privacy notice informing users that their submitted content is used solely for phishing analysis and is not retained. A comprehensive privacy policy should also be established prior to public deployment to ensure transparency and compliance with data protection requirements.

© UMHackathon 2026

Email: umhackathon@um.edu.my

Risk 4: User Trust in Bot Verdicts

If the bot incorrectly returns a Low Risk verdict for a URL that later causes harm, it can negatively impact user trust and make the tool counterproductive. To mitigate this, all Low Risk verdicts are accompanied by a clear disclaimer such as: *"No threats detected at this time. Always be cautious when entering credentials on any website."* The system is designed to avoid implying absolute safety; instead, it communicates outcomes as evidence-based and probabilistic. User education is embedded into every response to reinforce cautious behavior and reduce over-reliance on a single verdict.

© UMHackathon 2026